

WIRELESS NETWORK AND IOT SECURITY

Lecture 10: Wi-Fi Protected Access (WPA)

Instructor: Kui Ren



Wi-Fi Protected Access (WPA)

- Wi-Fi Protected Access (WPA) is
 - A response by the WLAN industry to offer an immediate, a stronger security solution than WEP.
- WPA is intended to be:
 - A software/firmware upgrade to existing access points
 - Inexpensive in terms of time and cost to implement
 - Compatible with vendors
 - Suitable for enterprise, small sites, home networks

How WPA Addresses the WEP Vulnerabilities

- WPA wraps RC4 cipher engine in four new algorithms
 1. A Message Integrity Code (MIC) called Michael
 - Designed for deployed hardware
 - Requires use of active countermeasures
 2. Extended 48-bit IV and IV Sequencing Rules
 - 2^{48} is a large number! More than 500 trillion
 - Sequencing rules specify how IVs are selected and verified
 3. Key Derivation and Distribution
 - Creating a key hierarchy out of the master key
 - Master keys can be refreshed in a secure manner
 4. Temporal Key Integrity Protocol generates per-packet keys

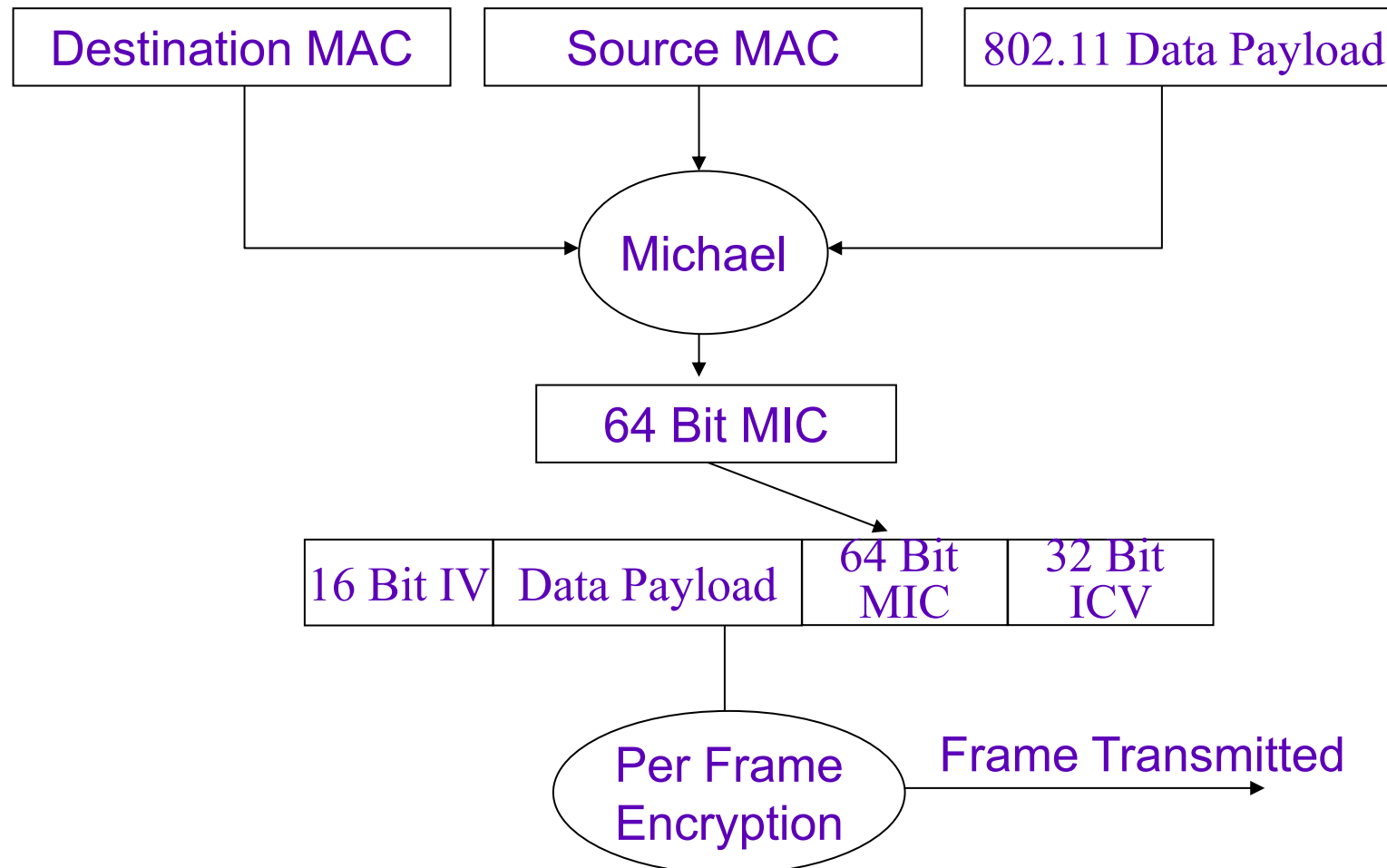
Key WPA Facts

- **Encryption method:** RC4
- **Key size:** 128 bits (varies)
 - Changes encryption key every frame
- **Key management:** TKIP
 - Resolves keys to be used, looks at client's configuration;
 - Sets unique default key for each client
- **Hash method:** Michael
 - 8 bytes, placed between data and ICV
- **802.1x authentication:** can be required

Message Integrity Check: Michael Algorithm

- Message Integrity Code (MIC) - 64-bit message calculated using the “Michael” algorithm
 - Designed for deployed legacy hardware
 - The Michael algorithm was the strongest that WPA designers could come up with that would still work with most older network cards
 - Uses a lot swaps, shifts, even discarding operations
- Protects both data and header
- The MIC is a hash that is calculated on a per-packet basis
- The MIC is also on a per-sender, per-receiver basis
 - The MIC is based on seed value (IVs), destination MAC, source MAC, and payload

Data Integrity: The Michael MIC Algorithm

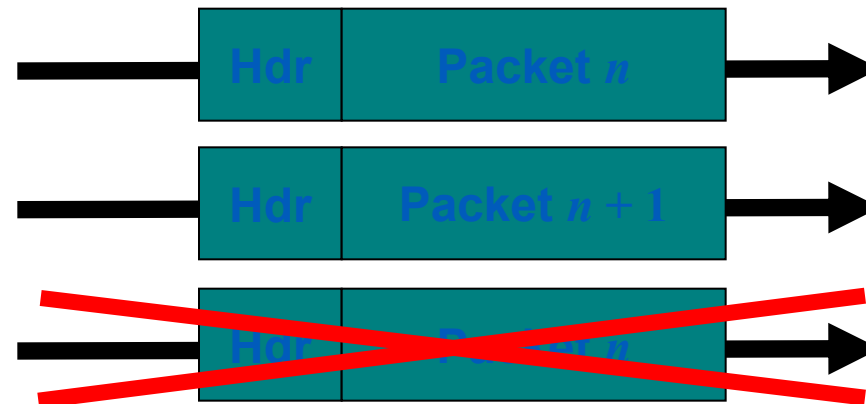


Defeating Replays: IV Sequence Enforcement

- Due to inevitable weaknesses of Michael, WPA implements a 16-bit monotonically incrementing counter **that discourages replay attacks**:
 - Take the 1st and 3rd bytes of the old IV
 - Reset packet sequence # to 0 on rekey
 - Increment sequence # by 1 on each packet
 - Drop any packet received out of sequence



Wireless
Station



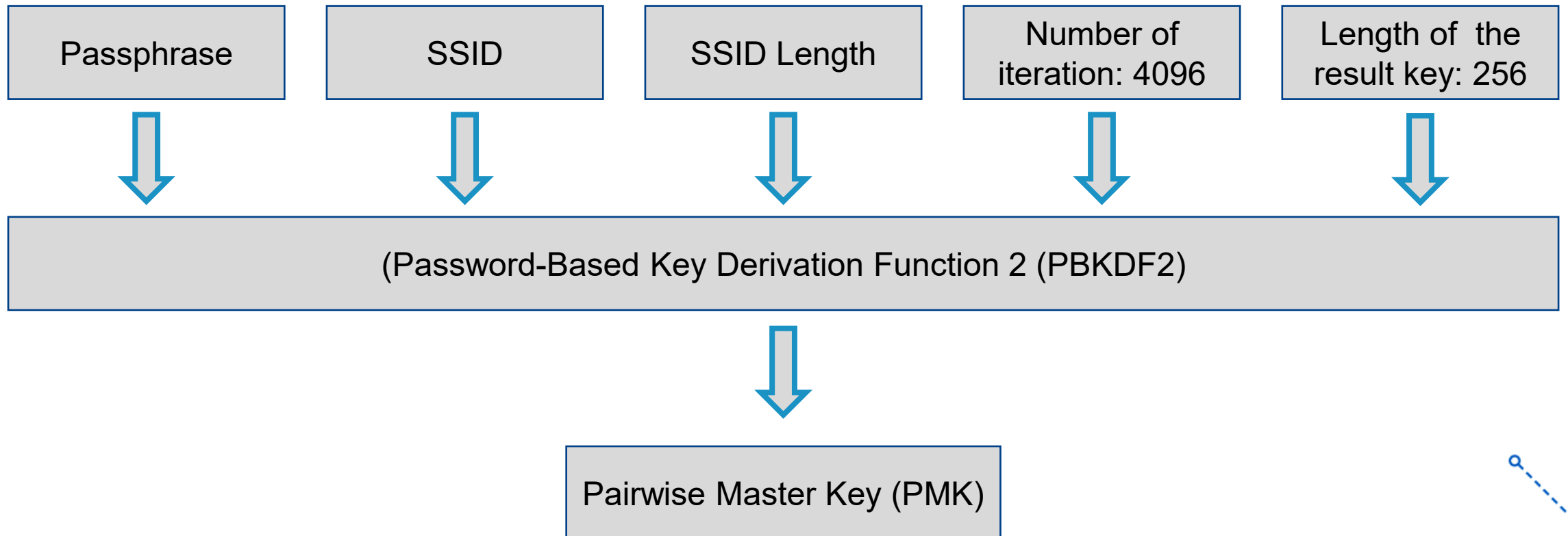
Access
Point



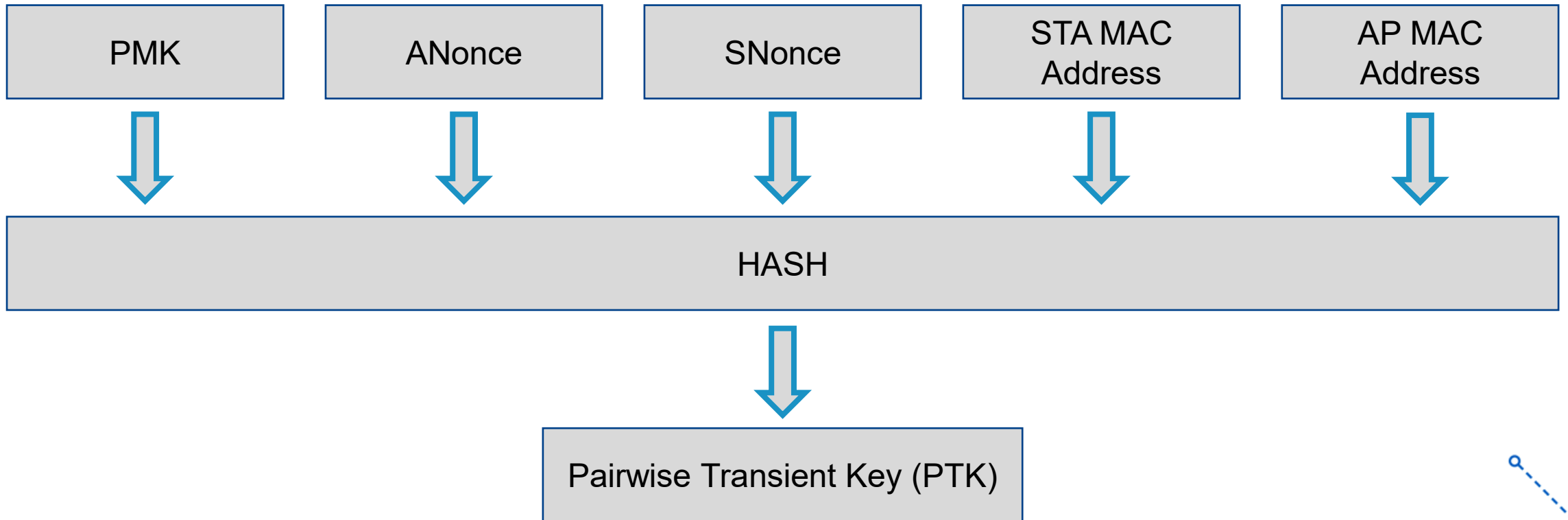
TKIP Re-Key Mechanism

- Refers to a process of delivering fresh encryption and integrity keys (MIC Keys) to the stations and Aps.
- WPA Key hierarchy consists of a master key and session keys
 - Master key, called the **Pairwise Master Key** (PMK), is derived from either an 802.1X key exchange or from the passphrase
 - Session keys, collectively called the **Pairwise Transient Key** (PTK), are derived from the master key

Pairwise Master Key (PMK) Construction

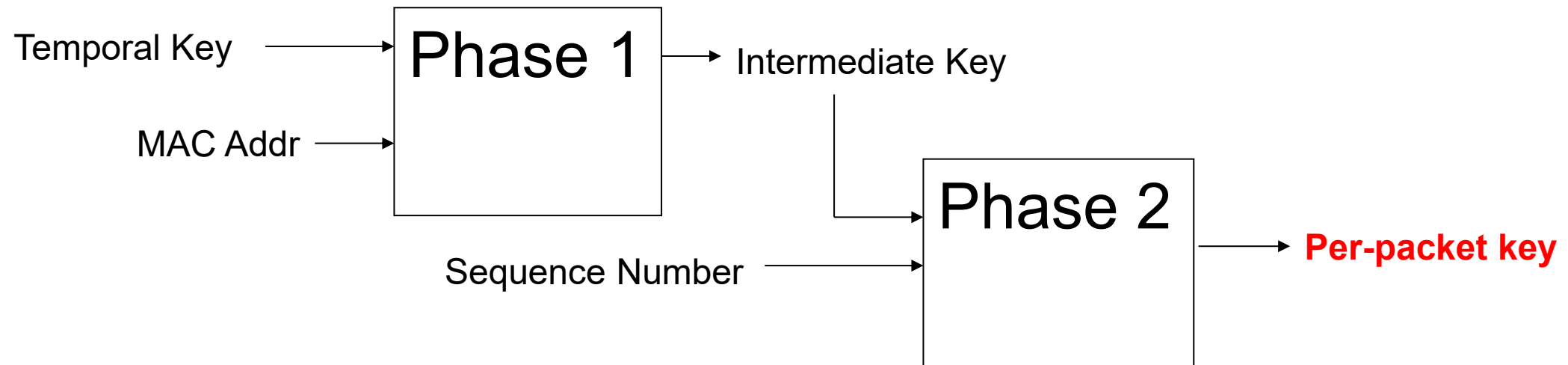


Pairwise Transient Key (PTK) Construction



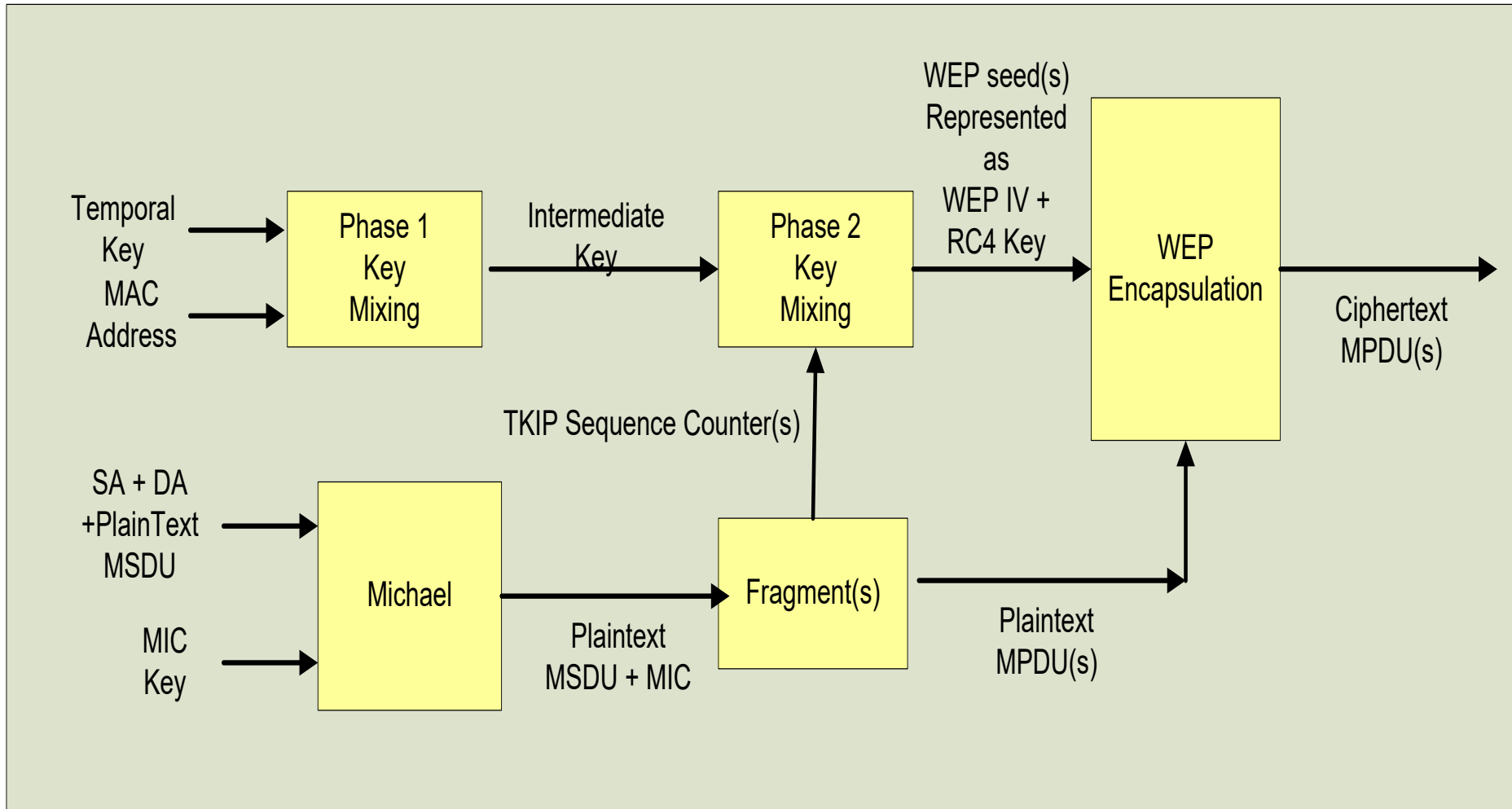
TKIP: Per-Packet Key Mixing

- **WEP** constructs a per-packet key by simply concatenating a base-key and the IV
- **TKIP** constructs a per-packet key by going through 2 key mixing phases
 - The mixing phases make difficult for an attacker to correlate IVs and per-packet key

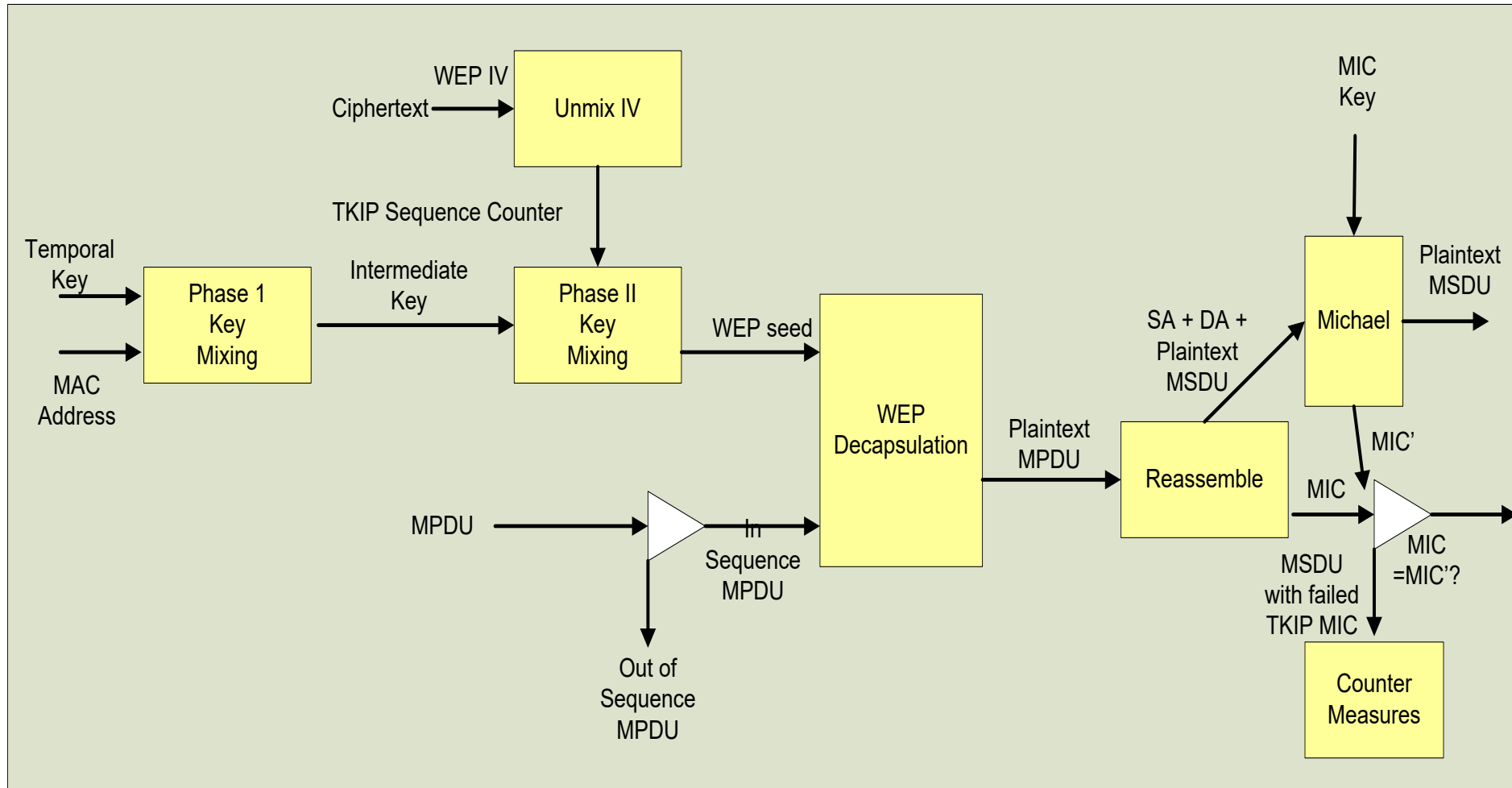




TKIP Encryption Process



TKIP Decryption Process



TKIP Summary

- TKIP appears to provide weak but genuine security
 - External review by Ron Rivest, David Wagner, John Kelsey, Susan Langford, and others
- TKIP meets goal of software deployment on almost all existing equipment
 - Does not appear to significantly degrade performance over WEP
 - Meets market's requirement for a migration path based on pre-existing installed base

How to Negotiate a Passphrase and PTK?

- **Pre-Shared Key Mode**

- No RADIUS server required
- “Shared Secret” is used for authentication to access point
- Management is handled on the AP
- Vulnerable to dictionary attacks

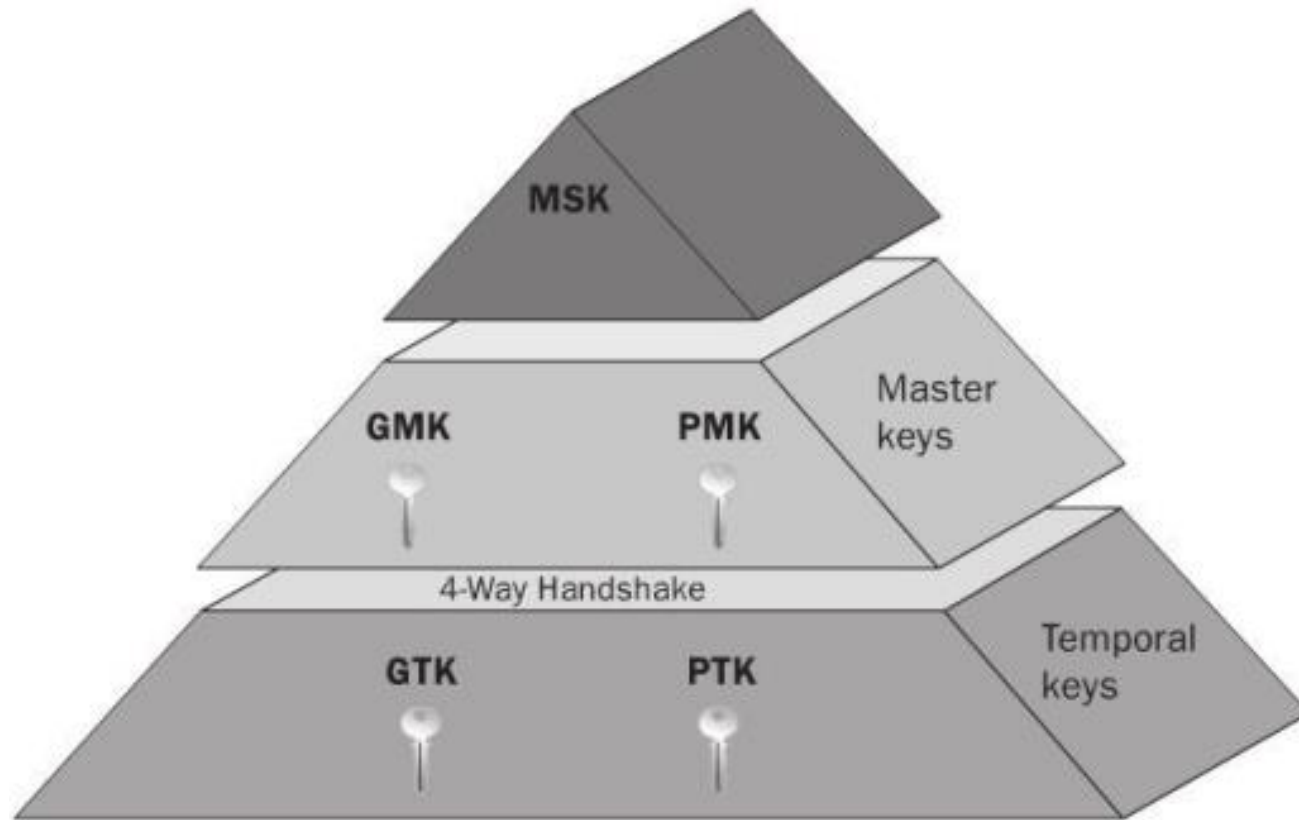
- **Enterprise Mode**

- Requires an authentication server
- Uses RADIUS protocols for authentication and key distribution
- Centralizes management of user credentials

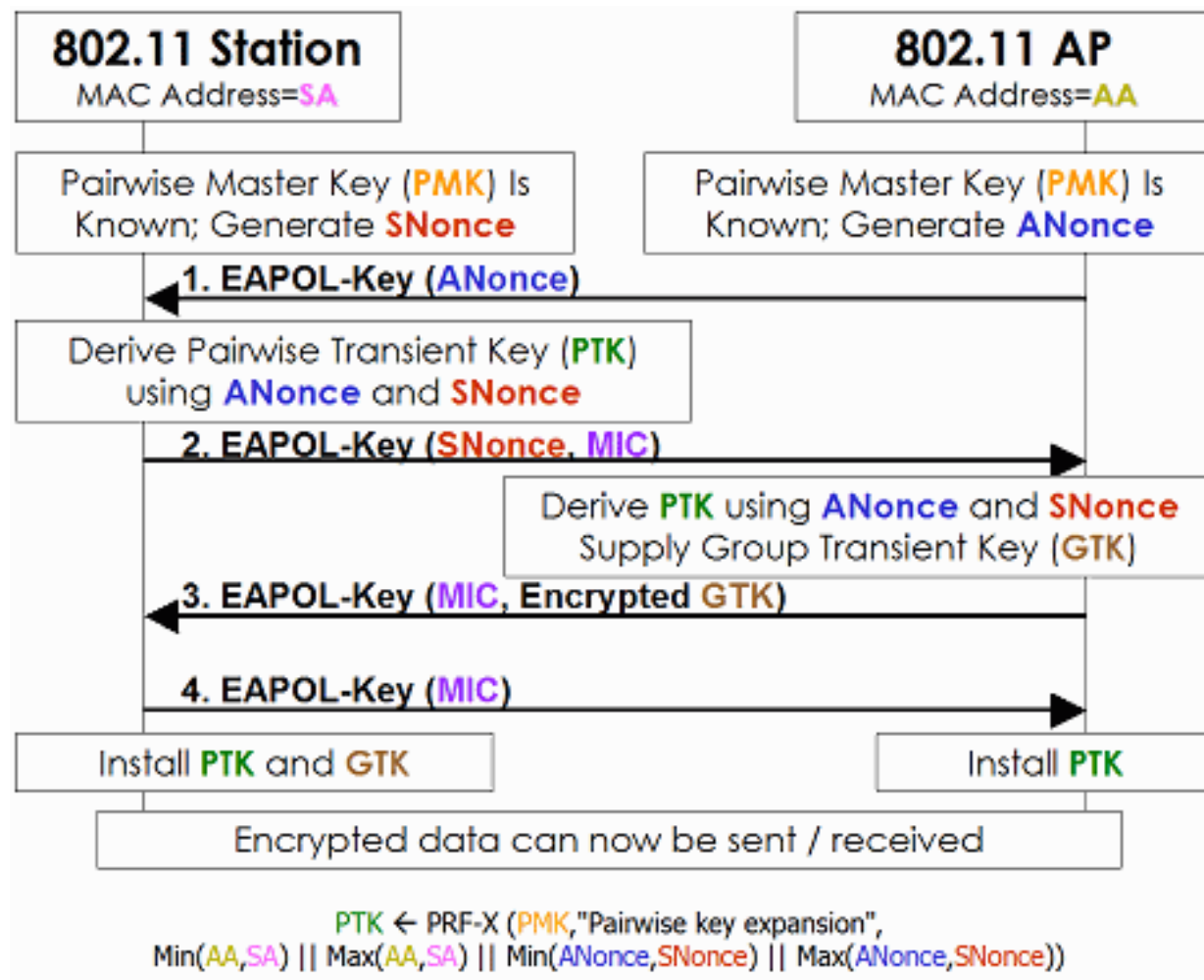
WPA-PSK Overview

- For home / SOHO use
 - Significantly increases the effort required to allow passive monitoring and decrypting of traffic
- Adopts **4-Way Handshake Authentication**
 - Also generates the secret session keys (PTK)
- Pre-shared Key + TKIP
 - No standardized way of changing shared secret
 - If shared secret becomes known, network security may be compromised
- Weak against passive dictionary attack
 - The more complex the shared secret, the less likely it will fall to dictionary attacks

The Role of 4-Way Handshake: Authentication and Key Exchange



PSK: 4-Way Handshake Authentication



Vulnerabilities of 4-way handshake

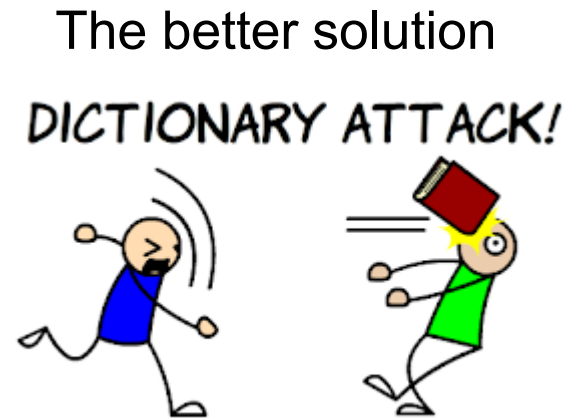
- 4-way handshake protected with PTK
- The strenght of PTK relies on the strength of the password
 - $\text{PSK} = \text{PBKDF2}(\text{Password}, \text{SSID}, \text{SSIDlength}, 4096, 256)$
- **Offline brute-force and dictionary attacks** possible
 - Attacker captures (records) 4-way handshake messages
 - Attacker performs brute-force or dictionary attacks (at home)

WPA-PSK: the Brute Force Attack

- How much time it will take to crack a simple passphrase with only alphanumerical values (upper and lower case)
 - Smallest WPA passphrase: 8 characters (max 63)
 - 62 possibilities per character: [A-Z][a-z][0-9]
 - $62^8 = 218\,340\,105\,584\,896$ possible keys
- Using a 280GTX processor (11000 keys/sec)
 - $218340105584896 / 11000 \text{ k/s} = 19\,849\,100\,508 \text{ sec}$
 - $19849100508 \text{ sec} = 5\,513\,639 \text{ hours}$
 - $5513639 \text{ hours} = 229\,735 \text{ days}$
 - $229735 \text{ days} = 630 \text{ years}$

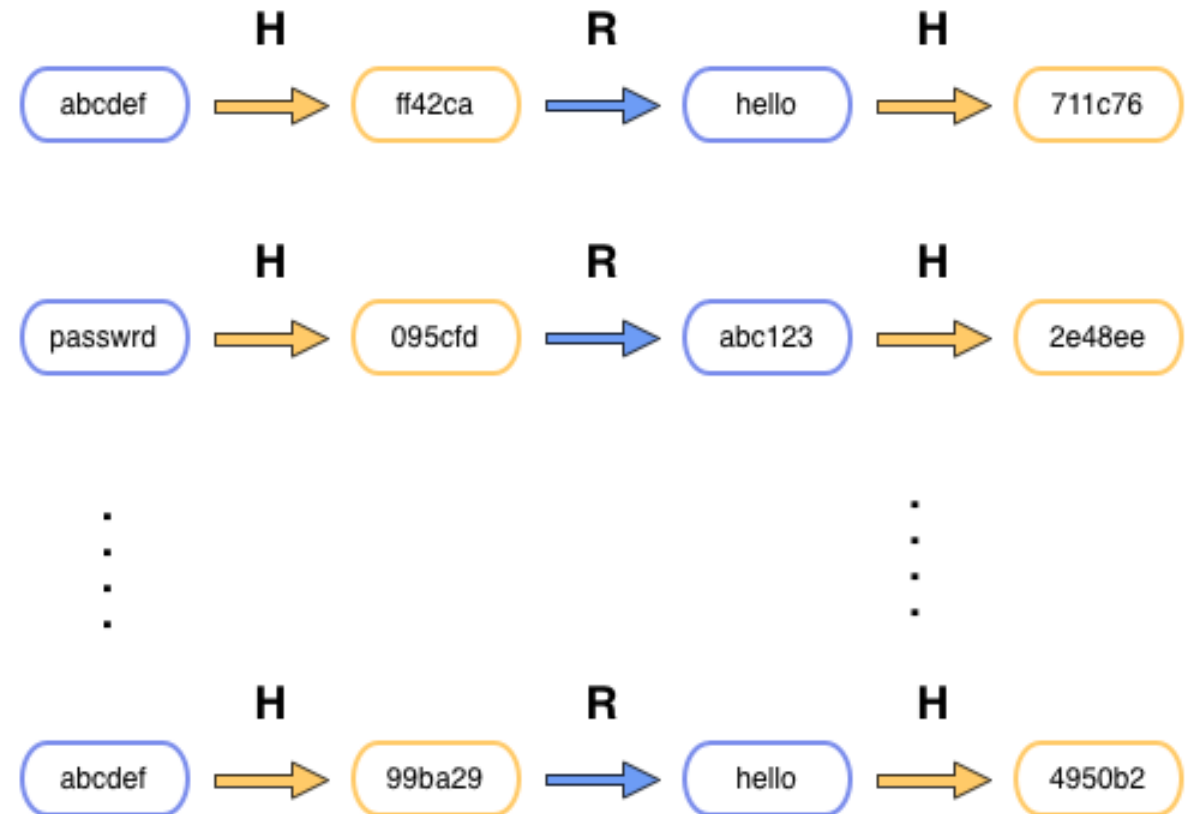
630 Years for an 8 Character Key

- A bit too long for a simple passphrase
- For a 12 character long passphrase, brute force will take 9 309 091 680 years.
- **Dictionary attack** is still the better solution.



WPA-PSK: Rainbow Table

- Rainbow tables are indexed hash lists
 - Pre-hash millions of words against top SSID's
 - Required 2-3 TB of space
 - Known tables exist for up to 14 characters
- Cracks WPA v1 and v2 with pre-shared key
- Drastically faster checking onsite



Suggestions for WPA-PSK

- WPA-PSK should be used with care
 - Vulnerable to external dictionary attacks, if short
- Choose WPA + 802.1X
 - No effective attacks found so far



WPA Enterprise Mode

- Authentication server distributes different keys to each user using 802.1X.
- Provide enhanced security and authentication
- Preferred for enterprise mode - business, government, education

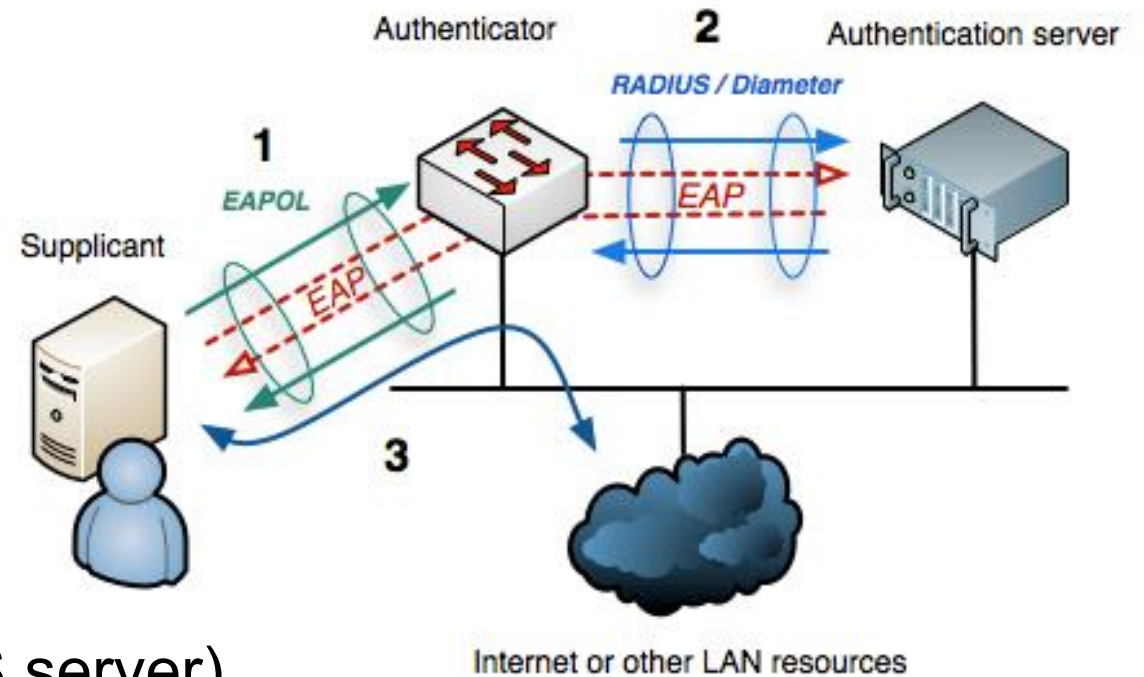


IEEE 802.1X

- 802.1X is an IEEE standard for port-based network access control for LANs
 - It fulfills the security loopholes of access control, authentication and key management in the 802.11 architecture
 - The authentication is usually done by a third-party entity, such as a RADIUS (Remote Authentication Dial In User Service) server

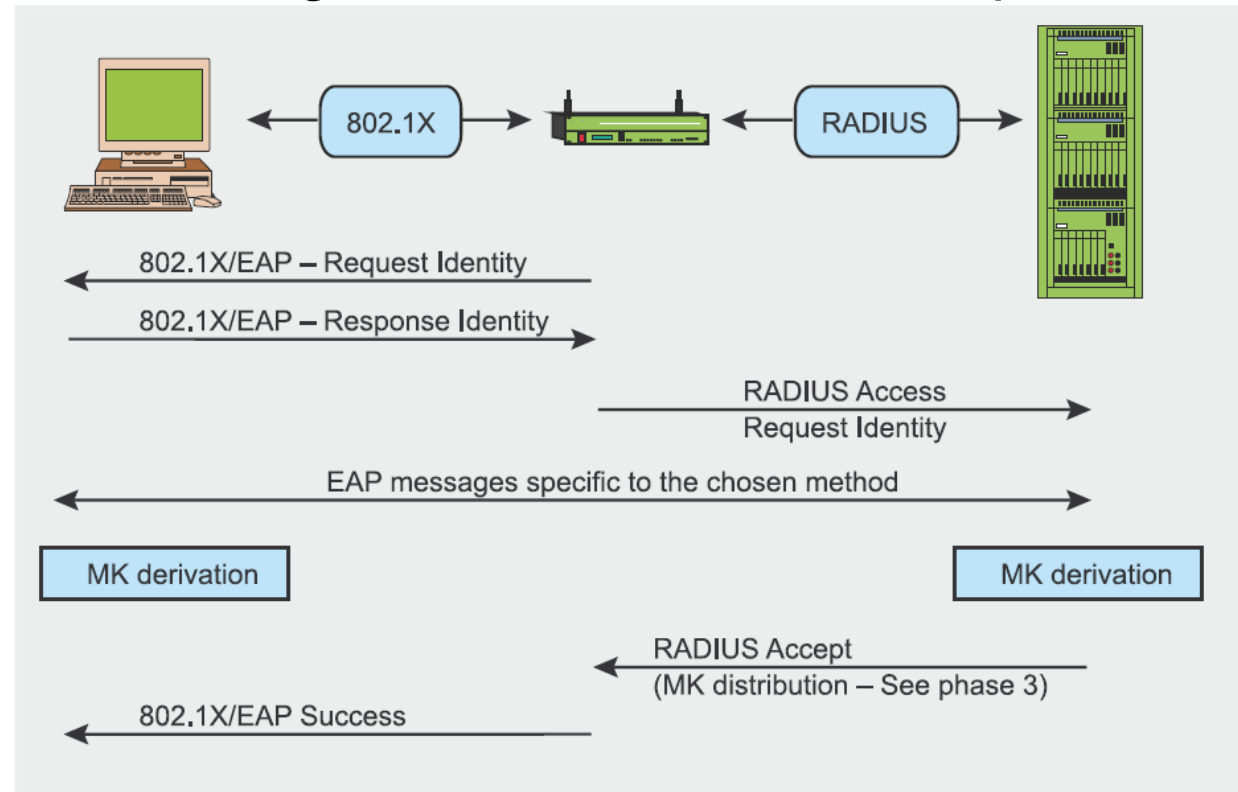
Main 802.1X components

- Supplicant (e.g., a wireless client)
- Authenticator (e.g., an Access Point)
- Authentication Server (e.g., a RADIUS server)



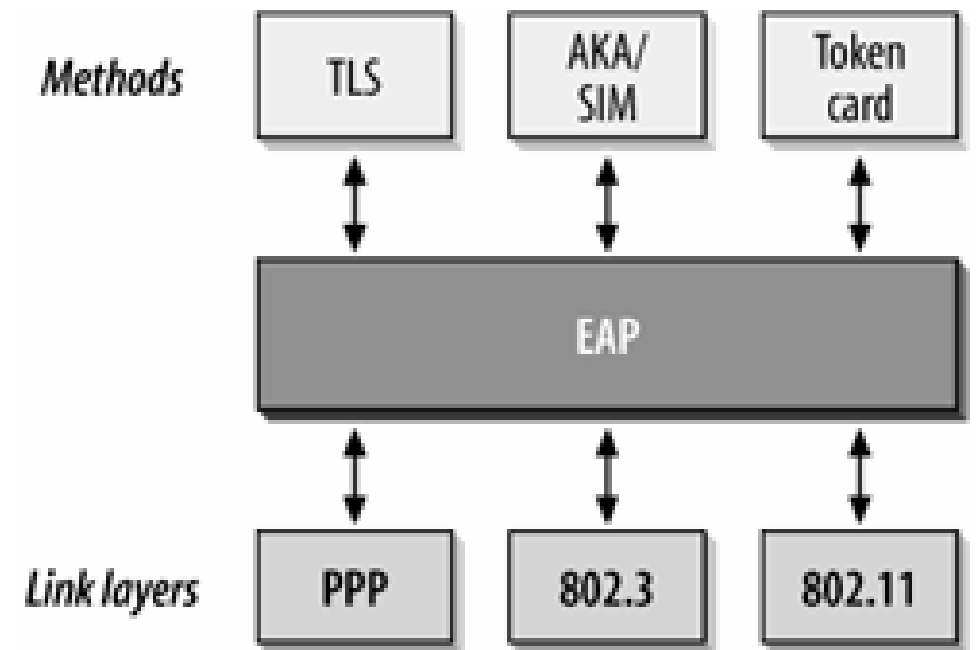
802.1X Authentication

- Based on **EAP (Extensible Authentication Protocol)** and the specific authentication method agreed in the association phase.



Extensible Authentication Protocol (EAP)

- A carrier protocol designed to transport the messages of “real” authentication protocols (e.g., TLS)
- It is a generic (flexible) authentication protocol that can run over any link layer protocol
- It Provides some common functions and a negotiation of the desired authentication mechanism called methods.

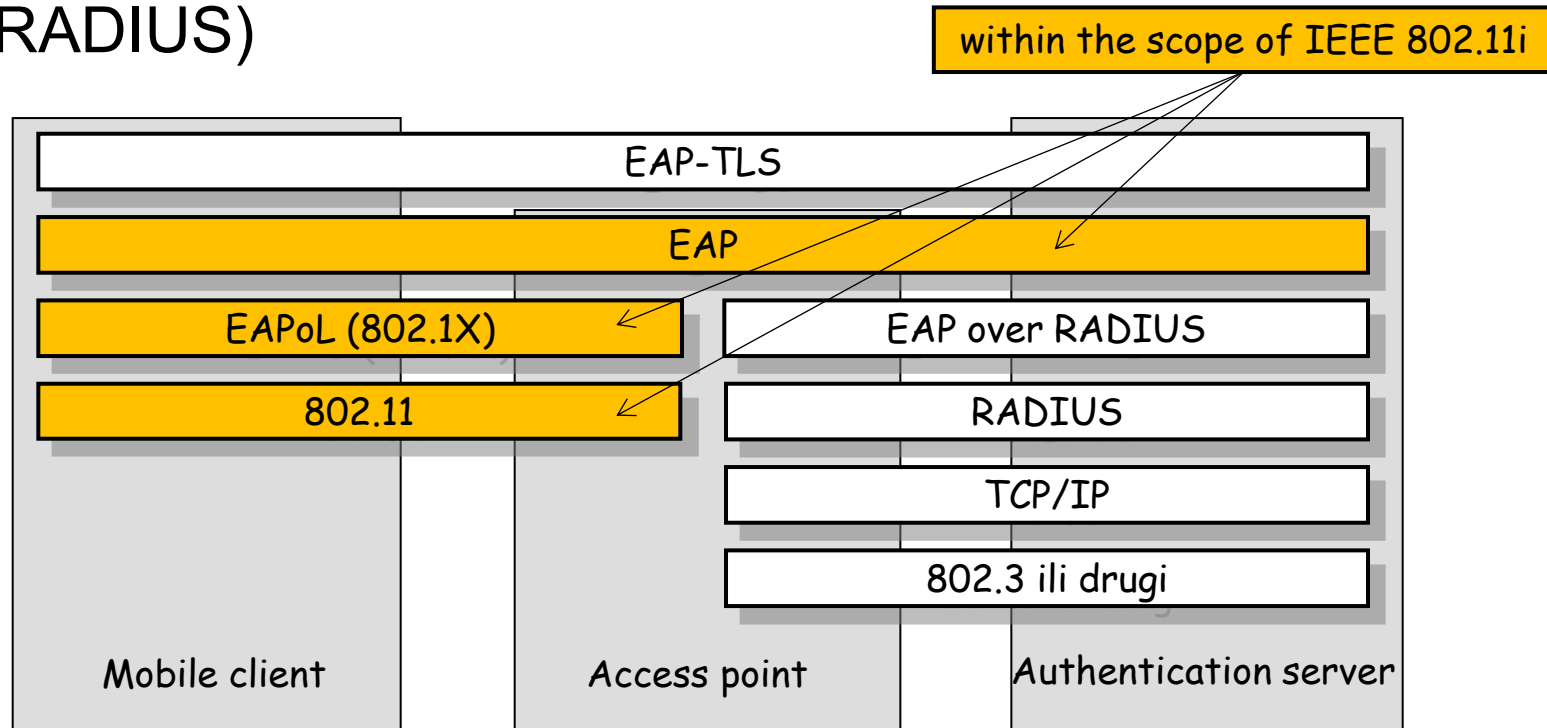


Extensible Authentication Protocol (EAP)

- EAP is very simple, only four types of messages:
 - EAP request – carries messages from AS to M
 - EAP response – carries messages from M to the AS
 - EAP success – signals successful authentication
 - EAP failure – signals authentication failure
- Authenticator (AP) doesn't understand what is inside the EAP messages, it recognizes only EAP success and failure
- EAP is not an authentication method itself

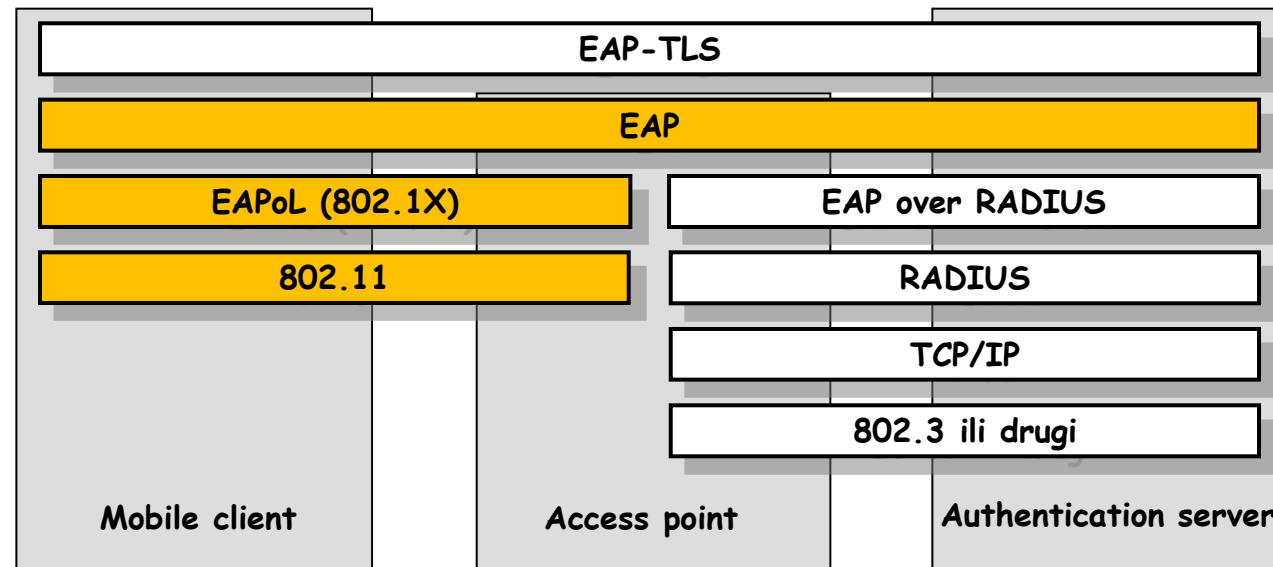
Extensible Authentication Protocol (EAP)

- End-to-end transport between client and authentication server
- AP proxies EAP between 802.1X and backend protocol between AP and AS (e.g. RADIUS)

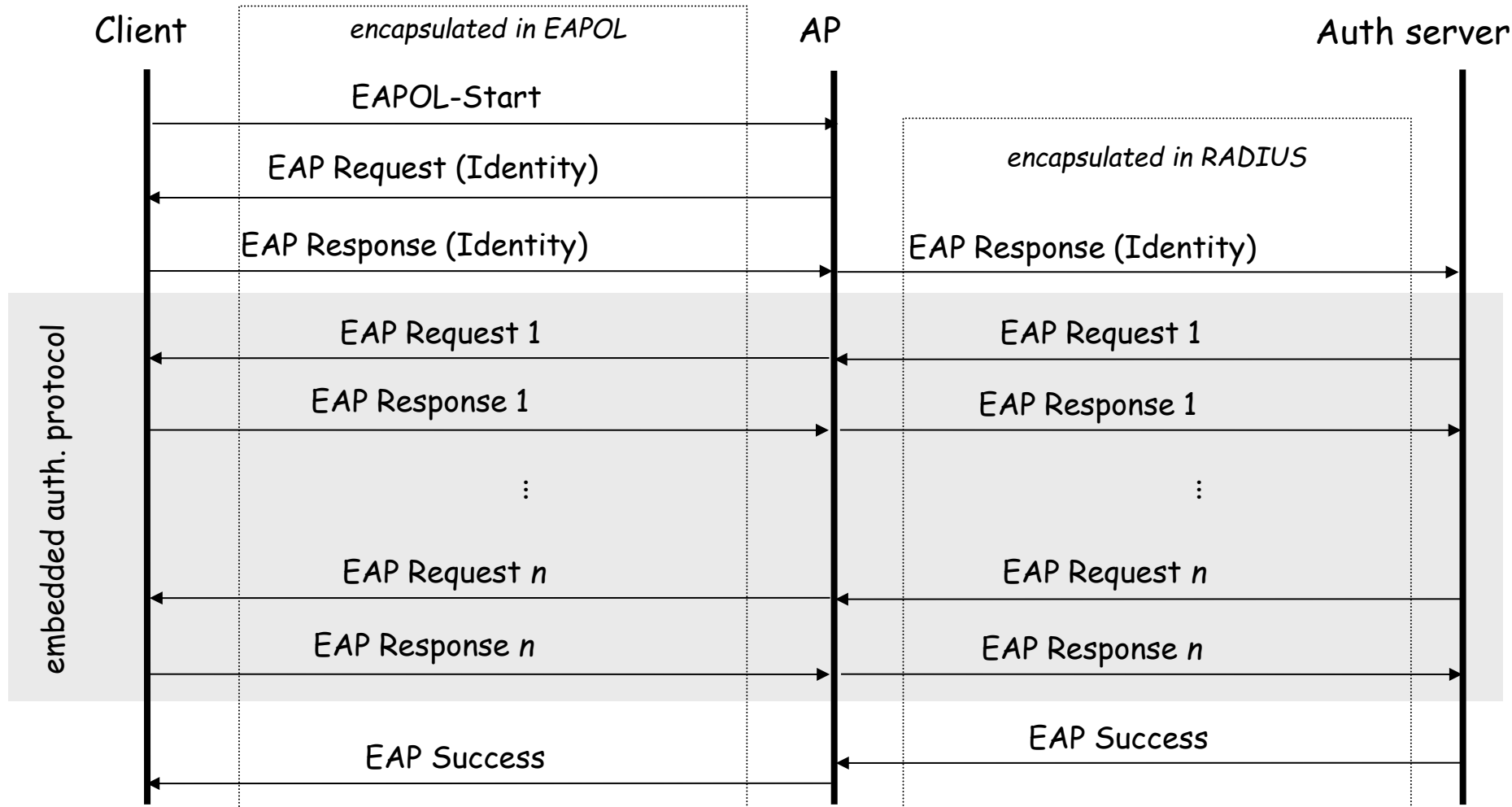


Extensible Authentication Protocol (EAP)

- EAPoL (EAP over LAN) [802.1X]
 - Encapsulate EAP messages into LAN protocols (e.g., Ethernet)
 - Used to carry EAP messages between the client and the AP
- RADIUS (Remote Access Dial-In User Service)
 - Used to carry EAP messages between the AP and the authentication server



EAP in Action



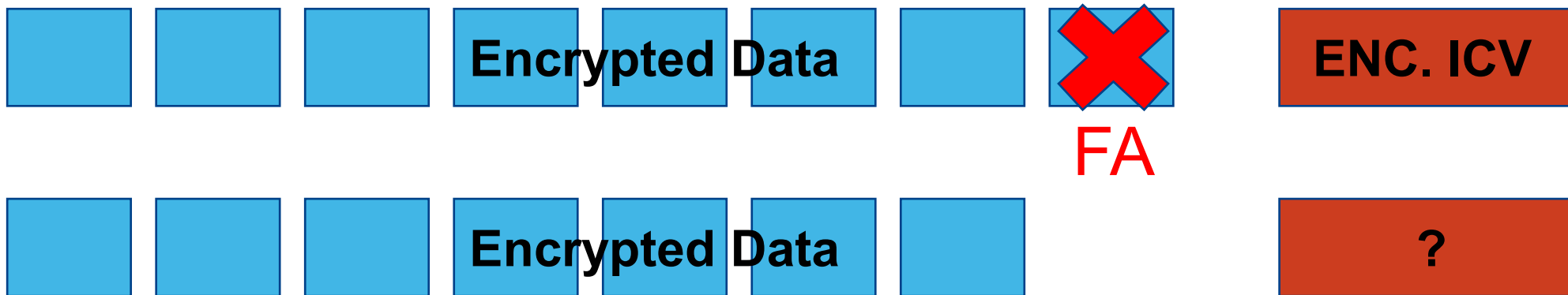
IEEE 802.1X authentication summary

- At the end of authentication:
 - The authentication server and client have established a session
 - The authentication server and client possess a mutually authenticated Master Key (derived from the concrete EAP method)
 - Master Key represents decision to grant access based on authentication
 - Client and authentication server have derived PMK (Pairwise Master Key)
 - PMK is an authorization token to enforce access control decision at AP
 - Authentication server has distributed PMK to an AP

The Need for A Better (Long Term) Security Standard

- Still, TKIP is not a favorable solution due to the weakness of RC4
- Beck-Tews attack
 - Active attack based on **chopchop** method for recovering plaintext
 - Requires support for alternative QoS channels to by-pass anti-replay protection
 - Rate-limited since correctness of plaintext guess is indicated by MIC verification failure, and only 2 failures per minute are tolerated

The Beck-Tews attack: Chopchop Method



- Guess the value of the deleted byte and calculate new ICV

Guess	New ICV	Accepted?
00	ICV-1	No
01	ICV-2	No
...	...	...
FA	ICV-n	Yes!

The Beck-Tews attack

- Normally, in WPA, a falsified encrypted packet that is made from an encrypted packet accepted in the past **is discarded** since the value of IV is checked.
- However, the chopchop attack can be executed on WPA implementations those support **IEEE802.11e QoS features**, which allow **8 different channels** for different data flows, and each channel has the **TSC counter independently**.
- The attacker can capture an encrypted packet from one channel and execute the chopchop attack on **another channel** that has a smaller TSC counter.